Plano de Respostas aos Riscos

Projeto: Flux

Data: 04/11/2026

Versão: 2.0 — Entrega 2

1. Introdução

Este documento detalha as estratégias e ações específicas planejadas para lidar com os riscos identificados no projeto Flux, conforme o Plano de Gestão de Riscos e Respostas a Riscos (Entrega 1, de 22/09/2026). O projeto abrange a comunicação BLE/Wi-Fi de dispositivos IoT, o transporte da telemetria inercial a 100 Hz e os microsserviços em nuvem (Laravel, FastAPI, Redis e bancos de dados). O objetivo é reduzir as ameaças à confidencialidade, integridade e disponibilidade dos dados dos atletas e aproveitar oportunidades de melhoria técnica. As prioridades, os responsáveis e os status apresentados na tabela foram preservados da Entrega 1; os prazos individuais devem ser definidos e validados pela equipe.

2. Tabela de Respostas aos Riscos

ID do Risco	Descrição do Risco	Nível do Risco (Prioridade)	Estratégia de Resposta	Ações Específicas Planejadas	Responsável pela Ação	Prazo para Implementação	Status
SEC-001	Interceptação (Man-in-the-Middle) no canal BLE entre pulseira e aplicativo.	Extremo	Prevenir (Evitar)	1. Configurar autenticação mútua com BLE Secure Connections e troca de chaves ECDH. 2. Habilitar criptografia AES-128 nativa no SoC. 3. Validar o pareamento e verificar a resistência à interceptação em testes autorizados.	Gabriel Debastiani Davanço	A definir (marco de segurança BLE)	Em Andamento
RED-002	Perda de pacotes e atraso na telemetria contínua a 100 Hz.	Alto	Mitigar	1. Implementar serialização binária compacta com Protocol Buffers. 2. Utilizar fila circular (ring buffer) no firmware para absorver oscilações de transmissão. 3. Medir perda de pacotes, latência e continuidade da telemetria em testes de bancada.	Ricardo Liyudi Tetsuya	A definir (validação de telemetria)	Em Andamento
SEC-003	Negação de serviço (DoS/DDoS) no microsserviço de IA (FastAPI).	Alto	Mitigar	1. Configurar limitação de taxa (rate limiting) no gateway. 2. Desacoplar requisições de inferência por meio do Redis Broker. 3. Executar testes controlados de carga e monitorar erros, filas e disponibilidade.	Caroliny Rossi Bittencourt	A definir (validação do gateway)	Não Iniciado
RED-004	Interferência de radiofrequência (2,4 GHz) na quadra por múltiplos aparelhos.	Médio	Mitigar	1. Ativar salto adaptativo de frequência (AFH) na comunicação BLE. 2. Implementar reconexão automática silenciosa após falhas de enlace. 3. Testar estabilidade da conexão na presença de múltiplos dispositivos.	Ricardo Liyudi Tetsuya	A definir (teste de RF)	Não Iniciado
SEC-005	Exposição indevida do MongoDB ou PostgreSQL em rede pública.	Extremo	Prevenir (Evitar)	1. Manter MongoDB e PostgreSQL isolados em sub-redes privadas (VPC). 2. Restringir a comunicação interna aos serviços autorizados e utilizar mTLS. 3. Verificar regras de acesso e exposição de portas nas auditorias de rede.	Duda Lucena Miguel	A definir (revisão de configuração)	Concluído
EXT-006	Indisponibilidade ou queda da região da nuvem pública (AWS/GCP).	Médio	Transferir	1. Prever SLA contratual de 99,9% com o provedor. 2. Manter rotinas automáticas diárias de backup. 3. Garantir replicação externa e verificar periodicamente a capacidade de restauração.	Duda Lucena Miguel	A definir (revisão de SLA/backup)	Concluído

ID do Risco	Descrição do Risco	Nível do Risco (Prioridade)	Estratégia de Resposta	Ações Específicas Planejadas	Responsável pela Ação	Prazo para Implementação	Status
SEC-007	Sequestro de tokens de sessão no painel web administrativo.	Médio	Mitigar	1. Armazenar credenciais de sessão em cookies com HttpOnly e Secure. 2. Definir política SameSite adequada ao fluxo de autenticação. 3. Configurar expiração curta dos tokens e testar o encerramento de sessões.	Gabriel Debastiani Davanço	A definir (revisão de autenticação)	Não Iniciado
OPP-001	Adoção de MQTT com criptografia TLS como alternativa a WebSockets/requisições REST.	Alto	Explorar (Oportunidade)	1. Desenvolver prova de conceito (PoC) de MQTT sobre TLS. 2. Comparar latência, estabilidade e consumo energético com a comunicação atual. 3. Se houver benefício comprovado, planejar a adoção no fluxo de telemetria.	Ricardo Liyudi Tetsuya	A definir (conclusão da PoC)	Em Andamento

3. Detalhamento das Estratégias de Resposta

- **Prevenir (Evitar):** Mudar o plano do projeto para eliminar a ameaça por completo. Significa não realizar a atividade que contém o risco.
- **Transferir:** Repassar o impacto negativo do risco (e a responsabilidade pela resposta) para um terceiro. Não elimina o risco, apenas o transfere.
- **Mitigar:** Reduzir a probabilidade de ocorrência do risco e/ou seu impacto no projeto a um nível aceitável.
    - *Exemplo no Flux: usar rate limiting e Redis Broker para reduzir o impacto de DoS no FastAPI; utilizar ring buffer para minimizar perda de telemetria.*
- **Aceitar:** Nenhuma ação proativa é tomada para alterar o plano do projeto.
    - **Aceitação Ativa:** Criar uma reserva de contingência (tempo, dinheiro) para lidar com o risco caso ele ocorra.

3.2. Estratégias para Oportunidades (Riscos Positivos)

- *Exemplo no Flux: desenvolver uma prova de conceito de MQTT sobre TLS e adotá-lo caso os testes confirmem ganhos.*
- *Exemplo:* Investir em treinamento para a equipe sobre uma nova ferramenta que pode aumentar a produtividade.
- *Exemplo:* Formar uma *joint venture* ou parceria para desenvolver um novo recurso.
- *Exemplo:* Saber que um fornecedor pode oferecer um desconto, mas não tomar ações para garantir isso, apenas aproveitá-lo se for oferecido.

Este plano será revisado quinzenalmente, conforme a periodicidade definida na Entrega 1, e também nas auditorias previstas para cada marco do projeto interdisciplinar. Em cada revisão, a equipe verificará o progresso das ações, os resultados dos testes de BLE, RF, telemetria, APIs e infraestrutura, além da exposição dos serviços e da recuperação de backups. O campo “Status” será atualizado entre Não Iniciado, Em Andamento, Concluído ou Cancelado, mediante validação dos responsáveis. O gerente de projeto consolidará os registros e reavaliará probabilidade, impacto e prioridade quando surgirem novos riscos ou mudanças de arquitetura. Permanecem aplicáveis a tolerância nula à exposição de dados sensíveis e ao comprometimento de chaves BLE, a tolerância moderada à latência de relatórios históricos e a reserva de 15% do esforço e custo computacional para segurança e certificados TLS. Os prazos individuais da tabela devem ser acordados pela equipe no próximo planejamento; sua ausência na Entrega 1 não permite registrar datas como fatos.